

Audit Event Definition:

Define what actions must generate an audit log entry.

1. security-sensitive (authentication, permissions, access failures),
2. privacy-sensitive (data access, exports, report generation), or
3. governance actions (admin moderation, backups, configuration).

Audit Event Naming Conventions

- Event names use snake_case
- Outcomes are encoded in the event name or tags:
 - _success, _failure, _blocked
- Examples: login_success, login_failure, report_generation_blocked_k_threshold

Audit Event List

Authentication & Account Events

Event Name	Actor	Description	Data Logged
LOGIN_SUCCESS	User/ Admin/ Provider/ Researcher	Account successfully authenticates	Timestamp, account ID, role, IP address
LOGIN_FAILURE	Any	Invalid credentials submitted	Timestamp, attempted account ID, IP address
2FA_SUCCESS	Any	Correct 2FA code verified	Timestamp, account ID, method used
2FA_FAILURE	Any	Incorrect 2FA code submitted	Timestamp, account ID, method used
ACCESS_DENIED	Any	Actor attempts action without permission	Timestamp, attempted account ID, IP address
LOGOUT	Any	User logs out of the system	Timestamp, account ID

User & Health Data Events

Event Name	Actor	Description	Data Logged
FORM_SUBMITTED	User	User submits a completed health form	Timestamp, user ID, form ID
HEALTH_GOAL_UPDATED	User	User updates personal health goal	Timestamp, user ID, goal ID
PERSONAL_REPORT_GENERATED	User	User generates a personal report	Timestamp, user ID, report type

Researcher Events

Event Name	Actor	Description	Data Logged
COHORT_CREATED	Researcher	Researcher defines a new cohort	Timestamp, researcher ID, cohort ID
AGG_REPORT_GENERATED	Researcher	System generates aggregated anonymous report	Timestamp, cohort ID, metrics
CSV_EXPORT	Researcher	System generates and delivers CSV export	Timestamp, cohort ID, export ID
PRIVACY_THRESHOLD_BLOCKED	System	Report blocked due to cohort < k	Timestamp, cohort ID, reason

Provider Events

Event Name	Actor	Description	Data Logged
PATIENT_RECORD_ACCESSED	Provider	Provider accesses participant data	Timestamp, provider ID, user ID
PROVIDER_VIEWED_REPORT	Provider	Provider views report	Timestamp, provider ID, report ID
FEEDBACK_CREATED	Provider	Provider submits feedback	Timestamp, provider ID, report ID

Admin & Governance Events

Event Name	Actor	Description	Data Logged
AUDIT_LOG_VIEWED	Admin	Admin views audit logs	Timestamp, admin ID
REPORT_DELETED	Admin	Admin deletes problematic report	Timestamp, admin ID, report ID
BACKUP_CREATED	System	Database backup completed	Timestamp, backup ID
CONFIG_CHANGED	System	Privacy or system settings updated	Timestamp, admin ID, config key

Audit Log Schema Design

Field	Description
Field	Description
id	Unique audit log entry identifier
event	Machine-readable audit event name
user_type	Actor role (User, Researcher, Provider, Admin, System)
user_id	Actor account ID
auditable_type	Type of affected resource
auditable_id	Identifier of affected resource
old_values	Non-sensitive prior state (IDs only)
new_values	Non-sensitive updated state (IDs only)
tags	Metadata such as outcome or category
url	Request URL (if applicable)
ip_address	Source IP address
user_agent	Client user agent

Auditable Target Strategy

For audit events that are not naturally associated with a specific domain object (such as authentication and logout events), the system attaches audit records to the authenticated account entity. This ensures that all audit entries are consistently linked to a concrete auditable target while avoiding the need for a separate system-wide audit anchor.

Under this strategy, authentication-related events (e.g., login success, login failure, logout) use the user account model as the auditable entity. This approach simplifies audit queries, maintains

consistency with the existing auditing framework, and provides a clear trace of account-level activity without exposing sensitive data.

Implementation Mapping

- Event name → event
- Actor identity/role → user_id, user_type
- Resource affected → auditable_type, auditable_id
- Outcome / category → encoded in event name or tags
- Additional safe context → tags or structured JSON in new_values

Audit Logging Rules

- Audit logs are append-only and immutable
- Logs must never store:
 - Raw health values
 - Full form responses
 - Free-text provider notes
 - Direct identifiers (name, email, DOB, address)
- Only IDs, event codes, and minimal metadata may be recorded
- Audit logging failures must not block user actions but must be detectable by administrators

Retention and Access

- Audit logs are retained for two (2) years
- Only administrators may view or export audit logs
- Export actions are themselves audited
- Logs are securely deleted after retention expiry in accordance with privacy best practices